

AUDITORIA DE SISTEMAS

AUDITORIA MEDIANTE COBIT/ISO 27001

Informe técnico sobre valoración de video del curso de COBIT y página de ISO 27001

Fecha de elaboración:

Mayo, 2026

Nombre y Apellidos: Gerson Antonio Valdivia
Haxell Antonio Trejos Rodríguez

CLASE PRACTICA NO.8

Objetivo: Realizar investigación y valoración sobre la auditoria en base a COBIT y el estándar ISO 27001, según el contenido de video de curso COBIT y pagina relacionada con ISO 27001.

Descripción: En grupos de trabajo de máximo 2 personas, se deben revisar los videos y los acápites de la página que oriente el docente y luego elaborar un informe técnico que deberá subir en la asignación respectiva.

Aspectos de interés: es importante que cada grupo trabaje de manera coordinada, concentrarse cuando analizan los videos y el contenido del curso de ISO 27001. Tengan en cuenta que esta actividad se evaluara sobre la base de 7pts y debe subirse en el plazo que se establezca en la plataforma o repositorio. Fecha máxima de entrega: ***Domingo 17 de mayo 2025.***

Con sentido profesional y ético, de manera grupal realice las actividades que se orientan a continuación:

I. TOMANDO EN CONSIDERACION LOS VIDEOS DEL CURSO DE COBIT QUE LES COMPARTIO EL DOCENTE, REALICE LAS SIGUIENTES ACTIVIDADES

- a. Revisar videos el 3 al 10, debe tomar anotaciones y valor con su grupo los aspectos de mayor relevancia.
- b. Integrar en un informe técnico grupal, todos los aspectos relevantes que usted identifique para realizar una auditoria mediante COBIT.
- c. Posteriormente subirlo en el repositorio grupal que tienen para el proyecto.

El enlace del curso que pueden adquirir de COBIT, es el siguiente:

<https://www.udemy.com/share/101y263@chmL2Rlq8uieTIK8tgKmuZbU7dCe9BSZKArDYT0yah0iOiwK0DH-dyir1mGNo9cDgA==/>

Pero también en caso que no puedan realizar lo anterior, deben revisar los accesos a videos de COBIT, para que tengamos la información pertinente, según los aspectos mencionados en el inciso a).

<https://www.youtube.com/watch?v=W5J09MhcDek>

<https://www.youtube.com/watch?v=qo9rr-ZwTs>

<https://www.youtube.com/watch?v=ml3R90wd84>

INFORME TÉCNICO SOBRE VALORACIÓN DE VIDEOS DEL CURSO DE COBIT 2019

I. ANOTACIONES Y VALORACIÓN DE LOS ASPECTOS DE MAYOR RELEVANCIA

Tras el análisis de los videos sobre los fundamentos de COBIT 2019, se han identificado y valorado los siguientes pilares conceptuales y técnicos que estructuran este marco de trabajo:

1. Naturaleza y Propósito del Marco

COBIT 2019 no se concibe como una herramienta técnica aislada, sino como un marco de referencia de gobierno y gestión empresarial de la tecnología y la información. Actúa como una "sombrija" que cubre a toda la institución, articulando otras normativas o estándares específicos (como ITIL, ISO 9001 o ISO 27001) para asegurar que la tecnología funcione como un habilitador del negocio y no como un fin en sí mismo.

2. Separación Estructural: Gobierno vs. Gestión

Un aspecto de vital relevancia es la estricta separación de responsabilidades que exige el marco:

- **Gobierno (Dominio EDM - Evaluar, Dirigir y Monitorizar):** Es responsabilidad exclusiva de la alta dirección o el consejo de administración. Se enfoca en evaluar los casos de negocio, asegurar la entrega de valor, optimizar los riesgos y recursos, y garantizar la transparencia para las partes interesadas.
- **Gestión (Dominios APO, BAI, DSS y MEA):** Recae sobre la alta y media gerencia, quienes deben planificar, construir, entregar operaciones y monitorear el rendimiento de los servicios tecnológicos de acuerdo con las directrices dadas por el gobierno.

3. El Enfoque Holístico: Los 7 Componentes del Sistema de Gobierno

El éxito de COBIT 2019 radica en que no se limita a evaluar procesos documentales. Para que el sistema funcione adecuadamente, interactúan siete componentes inseparables:

1. Procesos (prácticas y actividades).
2. Estructuras organizativas (roles, comités y matrices RACI).
3. Flujos y elementos de Información.
4. Personas, habilidades y competencias.
5. Principios, políticas y procedimientos.
6. Cultura, ética y comportamiento.
7. Servicios, infraestructura y aplicaciones.

4. Adaptabilidad y Personalización: Los 11 Factores de Diseño

COBIT 2019 abandona el enfoque de "talla única". Reconoce que cada organización es distinta y permite priorizar los objetivos de gobierno mediante 11 factores de diseño. Entre los más destacados se encuentran la estrategia empresarial, el perfil de riesgo, el panorama de amenazas, los requisitos de cumplimiento normativo y el modelo de abastecimiento (como la adopción de computación en la nube o el outsourcing).

II. INTEGRACIÓN: ASPECTOS RELEVANTES PARA REALIZAR UNA AUDITORÍA MEDIANTE COBIT

A continuación, se detallan los aspectos críticos para estructurar una auditoría bajo este enfoque:

A. Auditoría de la Alineación Estratégica

El auditor debe verificar que las inversiones y esfuerzos de TI estén justificados.

- **Procedimiento:** Se debe rastrear la "Cascada de Metas" descrita en COBIT. El auditor solicitará evidencia de cómo las necesidades de las partes interesadas se tradujeron en metas empresariales, y cómo estas últimas derivaron en las 13 metas de alineamiento de TI. Si TI opera desconectada de la estrategia de la empresa, es un hallazgo crítico de auditoría.

B. Evaluación Integral de los 40 Objetivos y los 7 Componentes

El plan de auditoría debe estructurarse alrededor de los 40 objetivos (5 de gobierno y 35 de gestión). Sin embargo, la recolección de evidencia no debe limitarse a verificar si existe un "proceso" escrito. El auditor debe evaluar holísticamente cada objetivo cruzándolo con los 7 componentes:

- ¿Existen políticas claras (Principios)?
- ¿Las matrices RACI reflejan la realidad operativa (Estructuras Organizativas)?
- ¿El personal tiene el entrenamiento adecuado (Habilidades)?
- ¿Existe resistencia al cambio o evasión de controles (Cultura y Ética)?
- ¿Se utilizan herramientas automatizadas para la trazabilidad (Servicios e Infraestructura)?

C. Verificación del "Tailoring" (Factores de Diseño)

Un error común es auditar todos los procesos con el mismo nivel de rigor. El auditor competente debe validar el diseño del sistema de gobierno de la entidad.

- **Procedimiento:** Se debe revisar si la organización aplicó los factores de diseño (como su escenario de amenazas o sus obligaciones legales) para priorizar sus esfuerzos. Por ejemplo, si el modelo de prestación de servicios incluye subcontratación (outsourcing) o infraestructura en la nube, el auditor debe enfocarse profundamente en auditar los controles sobre los proveedores de servicios (Dominio APO).

D. Auditoría del Ciclo de Control Interno (Dominio MEA)

Dentro de COBIT, el dominio MEA (*Monitorizar, Evaluar y Valorar*) es el equivalente natural de la auditoría y el control de calidad.

- **Procedimiento:** El auditor debe evaluar si la propia organización se audita a sí misma. Se debe verificar la existencia de indicadores de rendimiento (KPIs), la gestión y reporte del control interno, y la evaluación continua del cumplimiento de los requisitos regulatorios externos.

E. Orientación hacia "Quick Wins" (Victorias Rápidas)

Durante la evaluación de la implementación de COBIT en una entidad, el auditor debe considerar la madurez del proyecto. Tal como lo recomiendan las mejores prácticas, las implementaciones exitosas se realizan de forma iterativa, buscando victorias tempranas que generen valor rápido y fortalezcan el compromiso de la alta dirección. El auditor debe reconocer este enfoque de mejora

continúa y no penalizar a la organización por no tener el 100% de los 40 objetivos implementados de golpe en el primer año.

Conclusión Técnica

Auditar mediante COBIT 2019 dota al profesional de un marco de referencia robusto que eleva la discusión desde la "falla técnica" hasta el "riesgo de negocio". Permite emitir dictámenes integrales sobre cómo la cultura, la estructura organizativa y las decisiones de la dirección ejecutiva están impactando directamente en la capacidad de la tecnología para mantener la continuidad, seguridad y rentabilidad de la institución.

II. **EN EL ENLACE DE LA PAGINA Curso Norma ISO 27001 <https://tinyurl.com/23ombf94>**

- a. Revise los aspectos que se consideran para realizar auditoria mediante la ISO 27001
- b. Revise y analice los siguientes acápites o componentes relacionados:
 - i. Principios Fundamentales
 - ii. Definiciones
 - iii. El Sistema de Gestión de S.I.
 - iv. El Contexto
 - v. Las Partes Interesadas
 - vi. El Alcance
 - vii. La Gestión por Procesos
 - viii. El Liderazgo
 - ix. La Política de Seguridad
- c. Integrar en un informe técnico grupal, todos los aspectos relevantes que usted identifique para realizar una auditoria mediante la ISO 27001.
- d. Posteriormente subirlo por medio de la tarea orientada en su repositorio.

Nota: La solución que realice por favor la sube al repositorio. Recuerden que siempre se usara el mismo espacio del grupo del proyecto, pero crear una carpeta con los dos miembros que resolvieron esta clase práctica.

II. ANÁLISIS DE LA NORMA ISO 27001 Y SU APLICACIÓN EN LA AUDITORÍA DE SISTEMAS

La implementación y auditoría de un Sistema de Gestión de Seguridad de la Información (SGSI) bajo el estándar ISO 27001 requiere una comprensión profunda de la estructura organizacional y de los procesos operativos. A continuación, se presenta el análisis detallado de los acápites normativos y su valoración desde la perspectiva del auditor de sistemas.

a y b. Revisión y Análisis de los Acápites Normativos

i. Principios Fundamentales

Los principios son las directrices ineludibles que dan sentido al SGSI. Un auditor no solo verifica documentos, sino que evalúa si la organización ha interiorizado estos principios:

- **Satisfacción de las Partes Interesadas:** El diseño del sistema y sus controles de seguridad deben estar orientados a proteger los intereses económicos, legales y éticos de clientes, empleados y la sociedad.
- **Liderazgo y compromiso:** Se evalúa si el liderazgo transita de una simple "jefatura" a una guía activa en todos los niveles.
- **Toma de decisiones basada en riesgos y evidencias:** El auditor buscará pruebas de que las decisiones estratégicas de seguridad se toman analizando vulnerabilidades y amenazas reales de manera preventiva, no solo reactiva.

- **Gestión por procesos y mejora continua:** El SGSI debe ser flexible y vivo. Un sistema estático de un año a otro es un hallazgo negativo ("bandera roja") para el auditor, ya que la mejora continua debe estar evidenciada.

ii. Definiciones

El dominio del vocabulario técnico es crucial para la fluidez de la auditoría. El auditor verifica que la organización maneje un lenguaje común estandarizado. Resulta crítico diferenciar entre conceptos emparejados que suelen ser motivo de no conformidades:

- *Corrección* (eliminar la falla inmediata) vs. *Acción Correctiva* (eliminar la causa raíz para evitar recurrencia).
- *Documento* (procedimientos vivos) vs. *Registro* (evidencia inmutable de un evento pasado, como un log de auditoría).
- La correcta comprensión de términos como Riesgo, Contexto y Partes Interesadas es evaluada desde las primeras entrevistas.

iii. El Sistema de Gestión de S.I. (SGSI)

El SGSI no opera en un entorno aislado ni requiere una "doble contabilidad" administrativa. El auditor evalúa su integración real con las operaciones diarias. Se analiza la correcta aplicación del **Ciclo de Deming (PDCA)** aplicado a la seguridad:

- *Plan:* Evaluación de riesgos de la información y definición de controles.
- *Do:* Implementación de controles de seguridad física y lógica.
- *Check:* Monitoreo de incidentes y auditorías internas.
- *Act:* Revisiones por la dirección y aplicación de acciones correctivas.

Se evalúa también la viabilidad de que la organización mantenga un Sistema de Gestión Integrado (por ejemplo, ISO 27001 junto a ISO 9001), gracias a la Estructura de Alto Nivel (Anexo SL).

iv. El Contexto

Antes de auditar controles técnicos, el auditor debe revisar el Contexto de la Organización.

- **Factores Externos:** Se analiza si la entidad ha documentado cómo las tendencias tecnológicas (nuevos ciberataques, IA), regulaciones legales, el entorno político o económico afectan la seguridad de su información.
- **Factores Internos:** Se auditan las debilidades y fortalezas internas, tales como la cultura empresarial frente a la ciberseguridad, las competencias del personal de TI, la modernidad de la infraestructura tecnológica y la situación financiera para solventar inversiones en seguridad.

v. Las Partes Interesadas

El auditor revisa la matriz de partes interesadas para confirmar que se han identificado a todos los actores relevantes (*stakeholders*) y sus expectativas de seguridad: clientes (privacidad de datos), empleados (acceso seguro), proveedores (conexiones VPN seguras, acuerdos de confidencialidad) y la administración pública (cumplimiento normativo, protección de datos personales).

vi. El Alcance

Uno de los pasos más críticos de la auditoría. El auditor debe corroborar qué está incluido y qué está excluido del SGSI.

- Se verifica que la estructura contenga: *Actividades + Productos/Servicios + Limitaciones* (ej. "Gestión de bases de datos de clientes para el área de facturación en la sede central").
- El auditor presta especial atención a exclusiones injustificadas. No es válido excluir procesos críticos simplemente para evitar auditar sus vulnerabilidades.

vii. La Gestión por Procesos

Se abandona la visión departamental tradicional. El auditor evalúa el **Mapa de Procesos** en materia de seguridad.

- Se revisan las "Fichas de Proceso" para garantizar que existen responsables claros (Propietarios de Proceso), entradas y salidas definidas, recursos técnicos asignados, indicadores de desempeño de seguridad (KPIs) e identificación constante de riesgos asociados a ese flujo de información específico.

viii. El Liderazgo

La cláusula de liderazgo impide delegar las responsabilidades de seguridad de la información. El auditor busca evidencia objetiva de la implicación de la Alta Dirección:

- Aprobación de presupuestos para infraestructura tecnológica y seguridad.
- Firma de la Política de Seguridad y su difusión a través de canales internos (intranet, discursos, comunicados).
- Participación en la Revisión del SGSI, asumiendo responsabilidad y rindiendo cuentas en caso de incidentes o brechas de seguridad.

ix. La Política de Seguridad

Se audita la Política de Seguridad de la Información como el documento rector.

- Debe ser apropiada a los activos de información de la organización (no una copia genérica de internet).
- Debe comprometerse con el cumplimiento legal y la mejora continua.
- El auditor realiza entrevistas aleatorias a diferentes niveles de la empresa para comprobar si la política ha sido **comunicada, entendida y aplicada**, verificando canales como la intranet corporativa, capacitaciones de inducción y tableros de anuncios.

c. Integración: Aspectos Relevantes para realizar una Auditoría mediante la ISO 27001

A nivel profesional, la ejecución de una auditoría de sistemas orientada a la ISO 27001 requiere que el auditor técnico asuma una postura holística, integrando las siguientes directrices estratégicas en su plan de trabajo:

1. **Auditoría Basada en el Riesgo:** El núcleo de la ISO 27001 no es implementar el cortafuegos más costoso, sino mitigar riesgos de manera proporcionada. El auditor debe solicitar la evaluación de riesgos (*Risk Assessment*) y la Declaración de Aplicabilidad (SoA). La auditoría se centrará en verificar que los controles seleccionados son efectivos contra las amenazas identificadas en el análisis de Contexto.

2. **Verificación de la Trazabilidad Documental y Operativa:** El auditor exige coherencia. Si una "Parte Interesada" (ej. un ente regulador) exige cifrado de datos, el auditor rastrea este requerimiento desde la evaluación inicial, pasando por el diseño del proceso, hasta llegar al registro técnico (log) que evidencia que la base de datos está encriptada.
3. **Evaluación de la Cultura y Competencia Organizacional:** Una gran parte de los incidentes de seguridad provienen del error humano. La auditoría ISO 27001 exige evaluar los planes de concienciación. El auditor verificará si los usuarios están capacitados frente a ataques de ingeniería social, gestión de contraseñas y uso de escritorio limpio.
4. **Integridad del Liderazgo Directivo:** El auditor no se limita a evaluar al departamento de TI o de Seguridad. Se debe evidenciar el liderazgo de la gerencia general mediante la asignación de roles claros, la provisión de recursos y su participación activa en la revisión anual del SGSI por parte de la dirección.
5. **Medición, Seguimiento y Tratamiento de No Conformidades:** El auditor evalúa los indicadores de seguridad y la gestión de incidentes. Se examinan minuciosamente los registros de violaciones pasadas para comprobar si se implementaron verdaderas *Acciones Correctivas* que eliminaron la causa raíz, demostrando así el cumplimiento del principio de Mejora Continua.